SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

A company hires you to test its network but gives you only one line authorization with no defined scope. Do you exhibit to prove impact? Justify your answer using ethical hacking principles

If I discover a critical vulnerability in a system that is not included in the authorization email. I will not exploit it without obtaining additional written permission.

Ethical Approach:

- Authorization: Test only systems that are explicitly authorized.

Scope limitation: Do not access (or) modify systems outside the agreed scope.

Responsible disclosure: Inform the client about the vulnerability through a secure communication channel.

Written approval: Request updated authorization before conducting further tests.

Non-malficence: Avoid actions that could cause damage or expose sensitive information.

Justification:

Exposing the vulnerability without permission could result in data loss, service disruption (or) legal consequences. A critical vulnerability does not automatically give the tester permission to exploit it. Therefore, I would report the issue and obtain written authorization before proceeding. This approach maintains professional integrity while helping the company improves its security.

2) You are conducting a penetration test its network and discovered that clients production database contains real customer financial data you test plan calls for exploiting a SQL injection vulnerabi -lities. How do you proceed without causing harm and what precautions should have been taken before it?

SQL injection is a vulnerability that occurs when an application incorrectly handles user input and allows database queries to be manipulated. If I discover this vulnerability in a production database containg real customer financial informa -tion. I must proceed with extreme care to protect customer privacy and prevent business disruption. steps to proceed safely.

1. Review the testing authorization. confirm that SQL injection testing and affected production application are included in the approved scope.
2. Refer a testing environment. whenever possible, reproduce the vulnerability in a staging environment containing dummy (or) anonymized date.
3. use non- destructive testing : harmless test inputs to confirm the vulnerability without extracting financial records (or) modifying database contents.
4. Avoid sensitive data exposure Do not access customer account details, passwords transactions, records (or) other confidential information unnecessarily.

5) Monitor system performance
Observe the applicants behaviour and stop testing if the database becomes unstable (or) unexpected sensitive information is exposed.

6) Notify the client
Inform the designated security contact about the vulnerability and its potential impact.

7) Prepare a detailed report.
Document the affected application, the evidence collected the possible consequences and recommended corrective actions.

Precautions before the engagement
- sign a contact and define the scope of testing
- obtain written authorization for production testing
- Establish backup and recovery procedures.

Justifications: The principles of confidentiality, integrity and availability must be maintained. The goal is to identify security weakness without harming customers (or) the buisness.

3) During a black-box penetration test, you accidentally trigger a DNS on a live condition server. causing an outage walk through what done to prevent and what is your responsibility now.
If my testing causes a production outage. I must act immediately and take responsibility.

Prevention steps:

1) Identify production systems and critical services before testing.
2) Avoid aggressive scans and high-volume requests without explicit approval
3) Use rate limits and safe testing methods.
4) Agree on testing windows and Emergency stop procedures
5) Monitor system performance throughout the test.

Actions after the outage :-

1) Stop the test immediately
2) Notify the client's designated emergency contact
3) Help the authorized technical team
4) Preserve logs and document the actions that caused the outage

Justification.

A penetration tester is responsible for conducting tests carefully and responding professionally when something goes wrong. Hinding the outrage (or) continuing the test could increase the damage. Immediate communi -cation cooperation and acculate documentation help restore trust and improve futuro testing practices.

Conclusion : An Ethical hacker is responsible not only for identifying vulnerabilities but also for minimizing harm and responding transparently when something goes wrong. Immediate cessation, prompt notification, recovery assistance and honest reporting are essential professional responsibilities.

Q4. Covert penetration Testing without informing the IT department

This situation describes a possible covert penetration test or red-team exercise.

Such testing evaluates wther an organization's security monitoring systems and personnal can detect and respond to realistic attacks.

I would not automatically reject the request, but I would ensure that the exercise is properly authorized, documented and controlled before beginning.

Ethical and legal considerations

- Defined scope : clearly identify the permitted systems, networks, accounts, techniques, and testing period
- Need to known confidentiality : The IT team may be intentionally excluded from advance notification, but the exercise must remain authorized by appropriate management.
- protection of Employees : Evaluate detection and response capabilities fairly without using the exercise to unfairly blame individual employees.
- Accountability : Maintain secure records of actions, incidents and approvals.

Steps to conduct the exercise responsibly

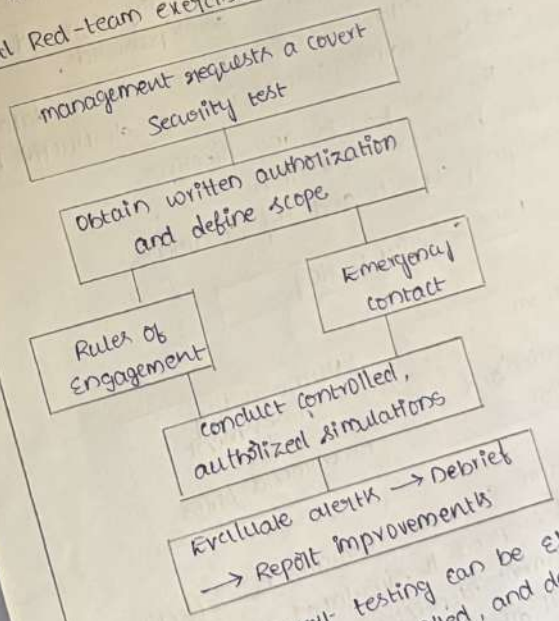
Obtain written approval from authorized management or the designated security authority.

Establish a trusted emergency contact who can authorize the exercise to stop.

Monitor the exercise to ensure it does not exceed the approved scope.

Stop immediately if a critical safety, privacy, or operational risk arises.

Ethical Red-team exercise



conclusion : Covert testing can be ethical when it is properly authorized, scoped, controlled, and designed to improve security.

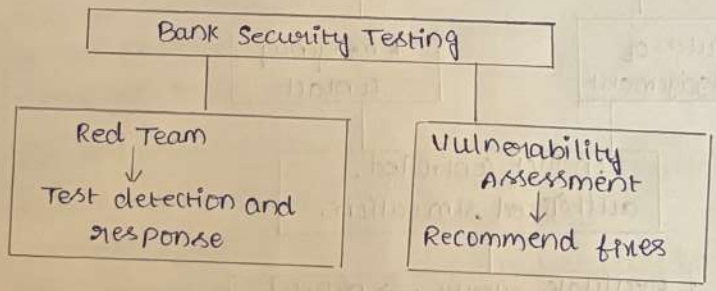
Keeping the IT team unaware may be necessary for realistic detection testing, but secrecy must never replace authorization, accountability, or harm prevention.

Q5. Red Team Exercise Vs Vulnerability Assessment

Scenario : A bank wants to evaluate it's physical and digital security to protect customer data and financial transactions.

Aspect	Red Team Exercise	Vulnerability Assement
Objective	Test the bank's ability to detect and realistic attacks.	Identify and report security weaknesses.
Digital security	Simulate controlled attacks on banking applications.	Identify outdated software, weak passwords.
Ethics	Obtain written permission and avoid harming customer.	Protect senitive data and use safe, destructive test.

clearly define the testing scope and objectives.
protect customer financial information
Establish emergency contacts and stop conditions.



Conclusion : A red team exercise evaluates how effectively the bank detects and responds to simulated attacks, where as a vulnerability assessment identifies security weaknesses without attempting a full attack.
Both requires written authorization, defined scope, confiden -tiality, and responsible reporting.